PROYECTO · PARTE 1 · DEFENSA ORAL

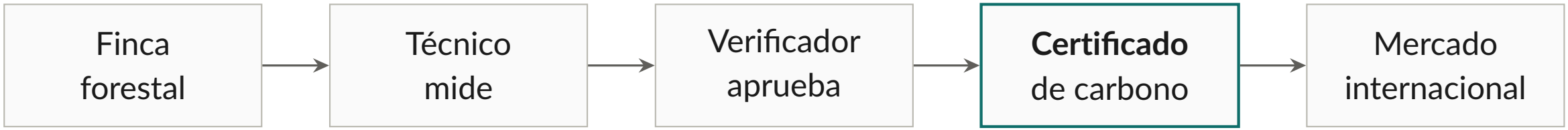
Diseño del control de acceso para Verdeazul Carbono

Políticas, matriz y arquitectura de seguridad

Randall Bolaños **Javier Tenorio** **Julio Varela** **Axel Flores**

Grupo 6 · CE-1115 Seguridad de la Información · Prof. MSc. Andrés Vargas Rivera · ITCR · 15 de octubre de 2026

Verdeazul vende confianza: cada certificado respalda una tonelada real



Un dato inflado es fraude.

Auditores europeos pueden pedir la trazabilidad de cualquier certificado de los últimos diez años.

Los dos sustos de la carta son fallas de integridad

PRIMER SUSTO	Una medición cambió después de aprobada, y nadie sabe quién fue.
SEGUNDO SUSTO	Un certificado se emitió dos veces sobre la misma hectárea.

Orden de prioridad: **integridad**, confidencialidad, disponibilidad.

Cuando dos pilares chocan, gana la integridad: sin registro en bitácora no hay acción.

Lo que más vale es lo que sostiene un certificado

ACTIVO	CLASIFICACIÓN	LO QUE NO PUEDE FALLAR
Mediciones y certificados	Confidencial	**Integridad**
Catálogo de fincas: la cartera	Confidencial	Integridad y confidencialidad
Datos personales de los dueños	Confidencial	Confidencialidad
Bitácora y llave de sello	Restringido	**Integridad**

El inventario completo tiene once activos, cada uno valorado en los tres pilares (informe de políticas, sección 2).

7 de 11 amenazas son internas: el atacante más probable ya tiene una cuenta

ID	YA OCURRIÓ EN VERDEAZUL	PILAR
AM-03	Una medición editada después de aprobarse	Integridad
AM-06	Un certificado emitido dos veces	Integridad
AM-04	Cientos de fincas consultadas en un fin de semana	Confidencialidad

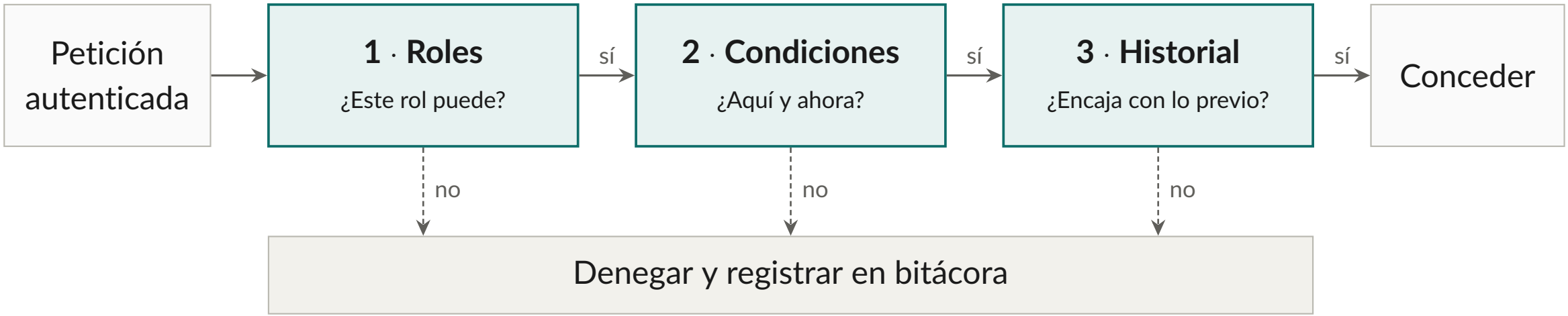
El diseño no mira el perímetro: mira qué puede hacer cada persona autorizada.

Cada obligación legal termina en una regla que se puede comprobar

NORMA	EXIGE	REGLA EN VERDEAZUL
Ley 8968, art. 14	Autorización para transferir datos	El auditor consulta en la plataforma
Reglamento, art. 38	Avisar una fuga en 5 días hábiles	Procedimiento con ese plazo
Ley 7975, art. 2	Medidas razonables de secreto	Acceso por necesidad y registro
ISO/IEC 17029	Quien revisa no participó	**Medir y aprobar, separados**

El cliente aclaró que no audita bajo una norma determinada: la ISO se cita como referencia. Su exigencia firme es la trazabilidad de diez años.

Roles con restricciones,
y condiciones que solo pueden quitar



Solo la primera capa concede. La matriz muestra lo máximo que cada rol puede llegar a hacer.

Los otros tres modelos fallan por razones de este caso

MODELO	POR QUÉ NO EN VERDEAZUL
DAC	Es lo que hay hoy: las hojas compartidas donde ocurrieron los dos sustos.
MAC	No hay niveles de secreto. Haría falta un compartimento por finca.
ABAC puro	Desaparece la fila que responde «¿qué puede hacer un verificador?».

De cada uno se conserva algo: la titularidad como atributo (DAC), la política que el usuario no puede alterar (MAC) y las condiciones acotadas (ABAC).

Siete roles hoy, y siete con el doble de fincas

El alcance nunca es un rol: es un atributo.

$RBAC_2$, sin jerarquía	Si el verificador heredara del técnico, podría registrar: se rompe la separación.
Explosión de roles	Aparece al usar un rol para decir dónde o cuándo. Aquí eso vive en las condiciones.
La consulta lo probó	Cinco necesidades nuevas: **un rol y cuatro atributos**.

Cuatro controles de historial, uno de cada tipo

	TIPO	QUÉ LO DISPARA	QUÉ DECIDE
H1	Frecuencia	Muchas fincas distintas en un día	**Tres niveles**: avisa, confirma, restringe
H2	Tiempo	Una decisión fuera de jornada	Pide segundo factor y motivo
H3	Combinada	Fuera de jornada, muchas fincas, casi todas nuevas	Confirma y avisa; si insiste, restringe
H4	Secuencia	Quien participó antes quiere decidir	**Deniega**

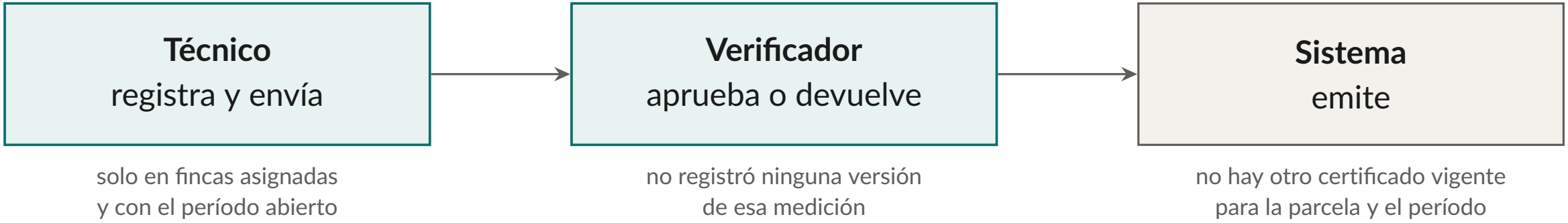
Ninguna señal aislada restringe: el cliente pidió avisar primero y no bloquear de inmediato (minuta, P-10).

El técnico del fin de semana hoy no vería ni una finca ajena

LO QUE HACE	LO QUE HACE EL SISTEMA
Abre una finca que no tiene asignada	**Deniega**: su rol no ve fincas ajenas
Insiste tres, cinco, diez veces	Avisa a su supervisor; pide segundo factor; lo detiene media hora
La necesitaba de verdad	El supervisor le da una asignación temporal, que vence sola
Presenta su renuncia	Reporte de sus consultas de 90 días

El cliente lo confirmó: fincas asignadas con flexibilidad, y respuesta según la gravedad (minuta, P-10 y P-11).

Nadie emite un certificado: lo hace el sistema



Ninguna persona tiene el permiso de emitir. **Hacen falta dos, y distintas.**

La separación se comprueba por medición, no por puesto

SI SE COMPRUEBA…	UN TÉCNICO ASCENDIDO A VERIFICADOR…
por el puesto de hoy	aprueba lo que él mismo midió el año anterior.
por la medición	**no puede: figura como autor.**

Técnica: **separación por etapas del flujo**, reforzada con roles mutuamente excluyentes.

Las alternativas se descartaron por lo que cuestan aquí

TÉCNICA	POR QUÉ NO ES LA PRINCIPAL
Roles excluyentes, solos	No cubren a quien cambia de puesto
Doble control (cuatro ojos)	**Duplica la verificación de cada certificado**
Segregación temporal	Limita cuándo, no quién
Rotación	No impide un acto; se recomienda contra la colusión

La segregación temporal sí se usa donde el problema es la duración: la asignación temporal, la habilitación del verificador, el plazo de la enmienda y la cuenta del auditor.

La fricción existe y está acotada

LO QUE CUESTA	CÓMO SE MANEJA
Siempre hacen falta dos personas	Mínimo dos verificadores; **sin atajo de emergencia**
Las devoluciones quitan tiempo de campo	Validación de rangos al registrar
Una enmienda pide tres personas	Plazo de diez días; el sistema la clasifica
La Gerencia concentra las segundas firmas	Nunca inicia lo que aprueba

Lo que no está escrito está denegado

	Fincas y parcelas	Datos personales del dueño	Períodos de medición	Asignaciones	Mediciones
TEC	leer C1	leer C1 (solo contacto)	leer	leer C1 (las propias)	leer C1, crear C2, modificar C2, enviar C2
VER	leer H	—	leer	—	leer H, aprobar C3, devolver C3
SUP	leer H	—	leer	leer, crear C19, modificar C19	leer H (solo estado y fechas)
GER	leer H, aprobar C11	leer H	leer, abrir C14, cerrar C14	leer	leer H
ADM	leer H, proponer C11	leer H, crear, modificar, eliminar C16	leer, crear, proponer C14	—	—
AUD	leer C6, exportar C18	leer C6	leer C6, exportar C18	leer C6, exportar C18	leer C6, exportar C18
DUE	leer C5	leer C5	leer	leer C5	leer C5 (solo aprobadas)
SIS	leer	leer (solo el nombre del titular)	leer	leer	leer
OPE	—	—	—	—	—
PUB	—	—	—	—	—

Matriz real, objetos 1 a 5 de 10. — sin acceso C*n* permiso sujeto a la regla *n* H lectura vigilada por historial

Nadie tiene «eliminar», y nadie emite

	Enmiendas	Certificados	Cuentas y roles	Bitácora	Alertas de historial
TEC	leer C1, solicitar C7, corregir C9	—	modificar C13	—	—
VER	leer, solicitar C7, revisar C10	leer H	modificar C13	—	—
SUP	leer (solo estado)	—	modificar C13	—	leer C15, resolver C15
GER	leer, solicitar C7, autorizar C8	leer H	leer, aprobar C12, modificar C13	leer	leer, resolver C15
ADM	—	—	leer, crear C12, desactivar C12, proponer C12, modificar C13	—	—
AUD	leer C6, exportar C18	leer C6, exportar C18	leer C6, modificar C13	leer C6, exportar C18	leer C6, exportar C18
DUE	leer C5	leer C5	modificar C13	—	—
SIS	leer	emitir C4, revocar C4	—	anexar	crear
OPE	—	—	—	—	—
PUB	—	comprobar C20	—	—	—

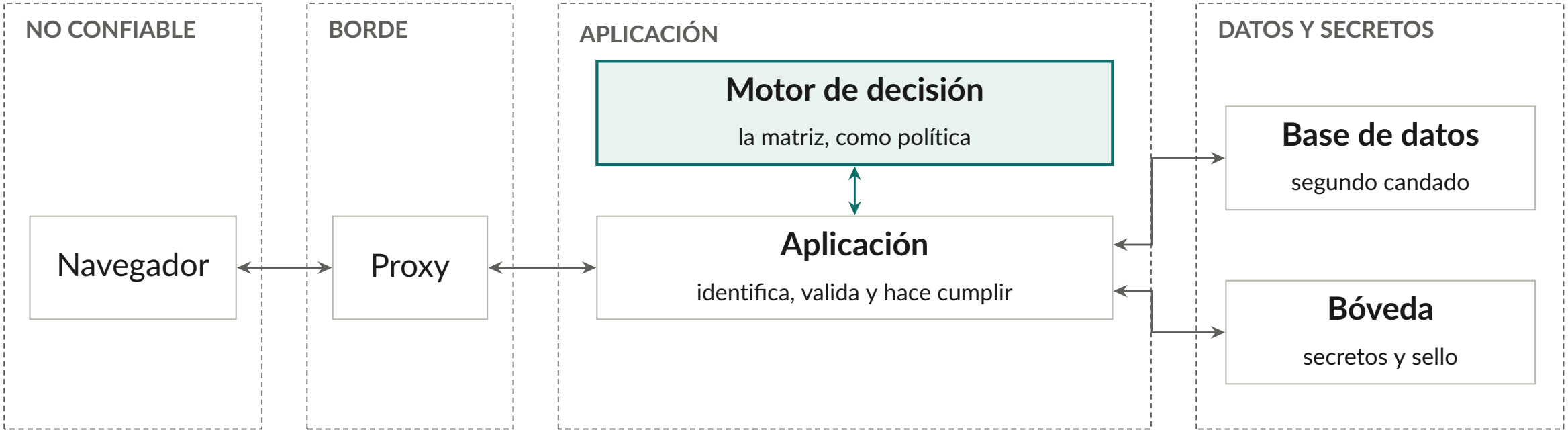
Matriz real, objetos 6 a 10 de 10. Toda decisión exige segundo factor reciente. **C17**: nadie decide sobre una finca con cuyo dueño declaró un vínculo.

Tres celdas bastan para leer la separación

	MEDICIONES	CERTIFICADOS
TEC	Crea, modifica y envía. Solo sus borradores, con el período abierto.	Sin acceso
VER	**Aprueba solo si no registró ninguna versión.**	Lee
SIS	Lee	**Emite solo si no hay otro vigente.**

Caso de prueba T-06: la verificadora que antes fue técnica intenta aprobar una medición que registró. Resultado esperado: deniega.

Un solo punto decide, en el servidor, antes de tocar el dato

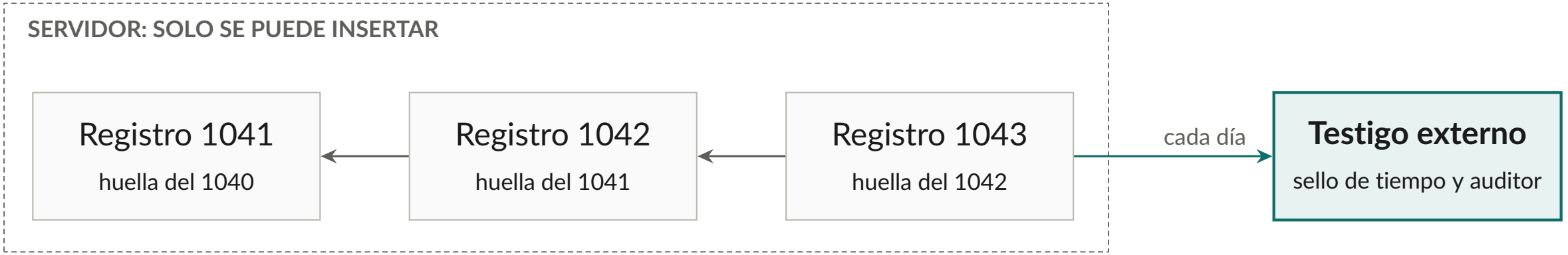


Esconder un botón no es autorización. Si el servidor no decide, cualquiera llama directo.

Seis tecnologías libres, elegidas por lo que protegen

DECISIÓN	ELECCIÓN	LO QUE APORTA
Lenguaje y framework	Python 3.14, Django 5.2 LTS	Consultas parametrizadas; escape por omisión
Base de datos	PostgreSQL 18	Seguridad por fila; emisión única
Sesión	De servidor, cookie opaca	**Se revoca en el acto**
Autorización	Open Policy Agent 1.21	Un solo lugar; la matriz como política
Contenedores	Podman sobre AlmaLinux 10	Sin privilegios; confinados por SELinux

La bitácora no la reescribe ni quien administra el servidor



Cambiar un registro rompe la cadena. Reescribirla entera no coincide con lo que ya salió.

Lo que no se cubre está declarado

RIESGO RESIDUAL	POR QUÉ SE ACEPTA
Colusión entre técnico y verificador	Evitarla exige una tercera persona por certificado
Una medición falsa desde el origen	El sistema no ve el árbol
Extracción lenta, bajo los umbrales	Bajarlos castiga a quien trabaja bien
Un vínculo con un dueño que nadie declaró	No existe un registro que lo descarte
El histórico de las hojas de cálculo	No se le puede dar la trazabilidad que no tuvo

El cliente respondió, y el diseño cambió en cinco puntos

	LO QUE RESPONDIÓ	QUÉ CAMBIÓ
P-01	Un verificador puede medir, por excepción	Habilitación temporal; no aprueba lo que midió
P-05	Las fincas las asignan los supervisores	**Rol nuevo: supervisor de campo**
P-06	La revisión sigue después del cierre	El cierre detiene registrar, no aprobar
P-07	Revisión técnica antes de autorizar	Solicitar, corregir, revisar, autorizar
P-10	Avisar primero; no bloquear de inmediato	Aviso, verificación, restricción temporal

Catorce de veintiséis consultas, respondidas por escrito. Las otras doce son supuestos declarados. Minuta: informe de políticas, Anexo A.

Cuatro decisiones que el cliente dejó en nuestras manos

LA PREGUNTA	LO QUE DECIDIMOS
¿Revisa un verificador distinto del original?	**Sí, cuando la enmienda es material**
¿Hace falta firma digital certificada?	No: sello de la empresa y comprobación en línea
¿Llaves físicas para todo el personal?	No: llave de acceso del propio equipo
¿Dónde se hospeda y quién lo opera?	Servidor virtual contratado; personal designado

El cliente pidió que cada decisión tenga una justificación clara y responda a un riesgo real, no el sistema más complejo.

Referencias principales

Abadi, M., & Fournet, C. (2003). Access control based on execution history. *NDSS*.

Clark, D. D., & Wilson, D. R. (1987). A comparison of commercial and military computer security policies. *IEEE S&P*.

Kuhn, D. R., Coyne, E. J., & Weil, T. R. (2010). Adding attributes to role-based access control. *Computer*, *43*(6).

Li, N., Tripunitara, M. V., & Bizri, Z. (2007). On mutually exclusive roles and separation-of-duty. *ACM TISSEC*, *10*(2).

Saltzer, J. H., & Schroeder, M. D. (1975). The protection of information in computer systems. *Proc. IEEE*, *63*(9).

Sandhu, R. S., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. *Computer*, *29*(2).

Schneier, B., & Kelsey, J. (1999). Secure audit logs to support computer forensics. *ACM TISSEC*, *2*(2).

Simon, R. T., & Zurko, M. E. (1997). Separation of duty in role-based environments. *CSFW*.

Temoshok, D., et al. (2025). *Digital identity guidelines: Authentication and authenticator management* (NIST SP 800-63B-4).

Ley N.° 8968 (2011) y su reglamento, Decreto N.° 37554-JP. Ley N.° 7975 (2000). Ley N.° 8454 (2005). Ley N.° 9048 (2012).

ISO/IEC 17029:2019. ISO 14065:2020. ISO/IEC 27001:2022.

Vargas Rivera, A. (2026). *Material de estudio del curso CE-1115 y enunciado del proyecto, parte 1*. ITCR.